

Αναφορά Άσκησης 8 Ασφάλειας Συστημάτων και Υπηρεσιών

Μέλη:

Χρήστος Καδάς, A.M: 2022030076

Κωνσταντίνος Κοντός, A.M: 2022030116

1. Εισαγωγή

Στην παρούσα εργασία υλοποιήθηκε ένα σενάριο προσομοίωσης επίθεσης ransomware σε περιβάλλον Docker, καθώς και εργαλεία ανίχνευσης της κακόβουλης δραστηριότητας. Ο στόχος ήταν η δημιουργία ενός σεναρίου κρυπτογράφησης αρχείων, η καταγραφή των ενεργειών μέσω ενός Access Control Logger και η επέκταση του εργαλείου παρακολούθησης (Monitor) για τον εντοπισμό μοτίβων ransomware.

2. Προετοιμασία Περιβάλλοντος (Environment Setup)

Για την εκτέλεση της άσκησης χρησιμοποιήθηκε το Docker image kostasamplia/ransom-lab-ubuntu:2025. Η δομή των φακέλων οργανώθηκε ως εξής:

- `../assignment`: Περιέχει τον πηγαίο κώδικα (bash script, C logger/monitor).
- `/data`: Χρησιμοποιήθηκε για την αποθήκευση των logs (access_audit.log).
- `/target`: Χρησιμοποιήθηκε ως ασφαλής φάκελος δοκιμών για την παραγωγή αρχείων προς κρυπτογράφηση.

Η εκτέλεση του container έγινε με bind mounts ώστε τα αρχεία να είναι προσβάσιμα τόσο από το host όσο και από το container .

3. Υλοποίηση Ransomware (Ransomware Implementation)

Δημιουργήθηκε το script ransomware.sh, το οποίο προσομοιώνει τη λειτουργία ενός ransomware.

Χρησιμοποιήσαμε το δικό μας rsa και δε χρειάστηκε καμία αλλαγή στο implementation. Προφανώς όμως δε γίνεται compile στο docker που μας δίνεται αφού λείπουν libraries όπως το gmp. Η αρχική ιδέα ήταν να χρησιμοποιήσουμε ένα static binary του rsa ώστε να δουλέψει με το docker αλλά αργότερα βρήκαμε πως αυτός ήταν ο λόγος που δε δούλευε ο logger.c αφού δεν καλούσε τις δικές μας fopen και fwrite.

Καταλήξαμε να φτιάξουμε ένα νέο docker βασισμένο στο docker που μας δόθηκε και τις βιβλιοθήκες που έλειπαν το βρίσκεται [εδώ](#) ως tar και μπορεί να χρησιμοποιηθεί με το command:

docker load -i my-ransom-lab.tar

Μέσα στο zip που περιέχει τα αρχεία της εργασίας βρίσκεται και το dockerfile που χρησιμοποιήσαμε για να φτιάξουμε το νέο docker

Το χτίσαμε με το command:

docker build -t my-ransom-lab .

Το τρέχουμε με το command:

```
docker run --rm -it \  
-v "$(pwd)/assignment:/home/student/assignment" \  
-v "$(pwd)/data:/home/student/data" \  
-v "$(pwd)/target:/home/student/target" \  
my-ransom-lab \  
bash
```

Χρήση: **LD_PRELOAD=./audit_logger.so ./ransomware.sh path n**

Παραδείγματα:

LD_PRELOAD=./audit_logger.so ./ransomware.sh /home/student/data 20

φτιάχνει και κρυπτογραφεί 20 αρχεία μέσα στο data

LD_PRELOAD=./audit_logger.so ./ransomware.sh /home/student/data
κρυπτογραφεί όλα τα αρχεία μέσα στο data, αν υπάρχουν

LD_PRELOAD=./audit_logger.so -d ./ransomware.sh /home/student/data

αποκρυπτογραφεί όλα τα αρχεία μέσα στο data

Παρατήρηση:

Αν φτιάξουμε 100 αρχεία και δεν υπήρχαν κλειδιά από πριν, θα δημιουργηθούν και αυτά, οπότε στο log θα φανούν 102 αρχεία.

Λειτουργικότητα Script

Το script εκτελεί τα εξής βήματα:

1. Δημιουργία Αρχείων (Burst Mode): Δέχεται ως όρισμα έναν κατάλογο-στόχο και έναν ακέραιο αριθμό, δημιουργώντας αντίστοιχα αρχεία κειμένου μεγέθους 10KB με επαναλαμβανόμενο περιεχόμενο ("This file WAS encrypted").
2. Παραγωγή Κλειδιών: Ελέγχει αν υπάρχουν κλειδιά RSA. Αν όχι, καλεί το custom εργαλείο μας (./rsa -g 1024) για να παράγει ζεύγος κλειδιών.
3. Κρυπτογράφηση: Διατρέχει όλα τα αρχεία στον κατάλογο και καλεί το εργαλείο RSA για να δημιουργήσει κρυπτογραφημένες εκδόσεις με κατάληξη .enc.
4. Διαγραφή: Μετά την επιτυχή κρυπτογράφηση, το αρχικό αρχείο διαγράφεται, υλοποιώντας το μοτίβο "Encryption-and-delete".
5. Αποκρυπτογράφηση: Υποστηρίζεται η επαναφορά των αρχείων με χρήση του flag -d, όπου το script χρησιμοποιεί το ιδιωτικό κλειδί για να ανακτήσει τα δεδομένα.

Εκτέλεση στον κατάλογο /data

Κατά την εκτέλεση του ransomware στον κατάλογο /data (mount από το host system), παρατηρήθηκε ότι η κρυπτογράφηση και η διαγραφή ολοκληρώθηκαν επιτυχώς. Αυτό συνέβη διότι ο χρήστης του container (student) είχε τα ίδια UID (1000) με τον χρήστη του host συστήματος, επιτρέποντας πλήρη δικαιώματα εγγραφής (Write/Execute). Αυτό αναδεικνύει την ανάγκη για την εφαρμογή της αρχής Least Privilege: Εάν ο κατάλογος είχε προσαρτηθεί ως Read-Only ή αν ο χρήστης του container ήταν διαφορετικός, η επίθεση θα είχε αποτύχει, προστατεύοντας τα δεδομένα του host

4. Καταγραφή Πρόσβασης (Access Control Logging)

Τεχνικές Λεπτομέρειες

- Καταγραφή Unlink: Προστέθηκαν συναρτήσεις interception για τις unlink και unlinkat ώστε να καταγράφεται η εντολή διαγραφής (rm), η οποία είναι κρίσιμη για την ανίχνευση του ransomware.
- Βελτιστοποίηση Hash: Αφαιρέθηκε ο υπολογισμός hash από τη συνάρτηση fwrite, διότι καλείται πολύ συχνά κατά τη δημιουργία και εγγραφή αρχείων σε σημείο που έσκαγε όταν προσπαθούσε να βρει το hash.
- Log Format: Κάθε εγγραφή περιλαμβάνει: UID, PID, FILE, DATE (UTC), TIME (UTC), OP, DENIED, και HASH .

5. Ανίχνευση Ransomware (Ransomware Detection)

Ανίχνευση Μαζικής Δημιουργίας Αρχείων

Ο monitor ανιχνεύει αν δημιουργήθηκαν πάνω από 100 αρχεία (Threshold) μέσα σε 20 λεπτά.

- Υλοποίηση: Χρησιμοποιείται σύγκριση της ώρας των logs με την τρέχουσα ώρα συστήματος (σε UTC). Ο κώδικας λαμβάνει υπόψη την αλλαγή ημέρας για να υπολογίζει σωστά τη διαφορά χρόνου ακόμα και αν τα logs αφορούν την προηγούμενη ημέρα.

Ανίχνευση Ροής Κρυπτογράφησης-και-Διαγραφής

Υλοποιήθηκε ανίχνευση του μοτίβου: Open → Create → Delete.

- Λογική: Το πρόγραμμα σαρώνει τα logs για εγγραφές διαγραφής (OP=4) σε μη κρυπτογραφημένα αρχεία. Για κάθε τέτοιο αρχείο, ελέγχει αν υπάρχει προηγούμενη εγγραφή δημιουργίας (OP=0) για το αντίστοιχο αρχείο με κατάληξη .enc.

6. Απαντήσεις στα Θεωρητικά Ερωτήματα

1. Γιατί η "ελάχιστη προνομιακή πρόσβαση" (least privilege) μειώνει τον αντίκτυπο (blast radius) του ransomware;

Η αρχή του least privilege περιορίζει τη ζημιά που μπορεί να προκαλέσει ένας μολυσμένος χρήστης μόνο στα αρχεία που έχει ρητά δικαίωμα να τροποποιήσει. Αν ένας απλός χρήστης μολυνθεί, το ransomware δεν θα μπορέσει να διαγράψει backups ή αρχεία διαχειριστών.

Παράδειγμα: Σε ένα εταιρικό δίκτυο, αν μολυνθεί ο υπολογιστής ενός πωλητή, το ransomware θα κρυπτογραφήσει μόνο τα δικά του έγγραφα και όχι τη βάση δεδομένων μισθοδοσίας ή τα shared drives του τμήματος IT, στα οποία δεν έχει πρόσβαση εγγραφής.

2. Γιατί τα "offline" ή "immutable" αντίγραφα ασφαλείας μειώνουν τον κίνδυνο σε σχέση με τα κοινά δικτυακά backups;

Τα ransomware σαρώνουν το δίκτυο για να βρουν και να καταστρέψουν τα backups. Τα offline backups είναι φυσικά αποσυνδεδεμένα, καθιστώντας αδύνατη την πρόσβαση από το malware. Τα immutable backups επιτρέπουν την εγγραφή δεδομένων αλλά απαγορεύουν τη διαγραφή ή τροποποίησή τους για ένα ορισμένο διάστημα, προστατεύοντας τα από κρυπτογράφηση.

3. Γιατί πολλά ransomware προσπαθούν να διαγράψουν τα backups πριν την κρυπτογράφηση και ποια είναι μια απλή στρατηγική άμυνας; Οι επιτιθέμενοι

διαγράφουν τα backups (π.χ. Shadow Copies) για να αναγκάσουν το θύμα να πληρώσει τα λύτρα, αφαιρώντας τη δυνατότητα δωρεάν ανάκτησης.

- Στρατηγική Άμυνας: Η εφαρμογή του κανόνα 3-2-1 backup: 3 αντίγραφα, σε 2 διαφορετικά μέσα, με 1 αντίγραφο εκτός τοποθεσίας/offline. Επίσης, η ενεργοποίηση Multi-Factor Authentication (MFA) για κάθε ενέργεια διαγραφής backups μπλοκάρει την αυτοματοποιημένη διαγραφή από το ransomware.